蓝盾队 WriteUp（撰写完成后导出为pdf文件提交至平台）

排名

战队名称：第7名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
1	我没招了	3837	Web	10	1	2025-09-11 16:53:19
2	东风5C队	3808.5	Web	10	0	2025-09-11 16:34:58
3	计划有变准备领奖队	3800	Web	10	0	2025-09-11 17:24:51
4	404NotFound-上海市分行	3562.5	Pwn	7	1	2025-09-11 16:50:46
5	交银国信	3551.5	Web	9	1	2025-09-11 17:29:15
6	西风骑士团	3512	Web	9	0	2025-[illegible] 17:08:31
7	蓝盾队	3511	Web	10	0	2025-[illegible] 17:23:22
8	白马队	3500	Web	9	0	2025-[illegible] 17:17:18
9	武汉战队	3456.5	Web	9	0	2025-[illegible] 16:17:12
10	AI合成注意甄别	3368.5	Web	8	2	2025-[illegible] 16:48:31

共 12 页 < 1 2 3 4 5 ... 12 >

解题思路

MISC

基米我们的感情好像叮咚鸡

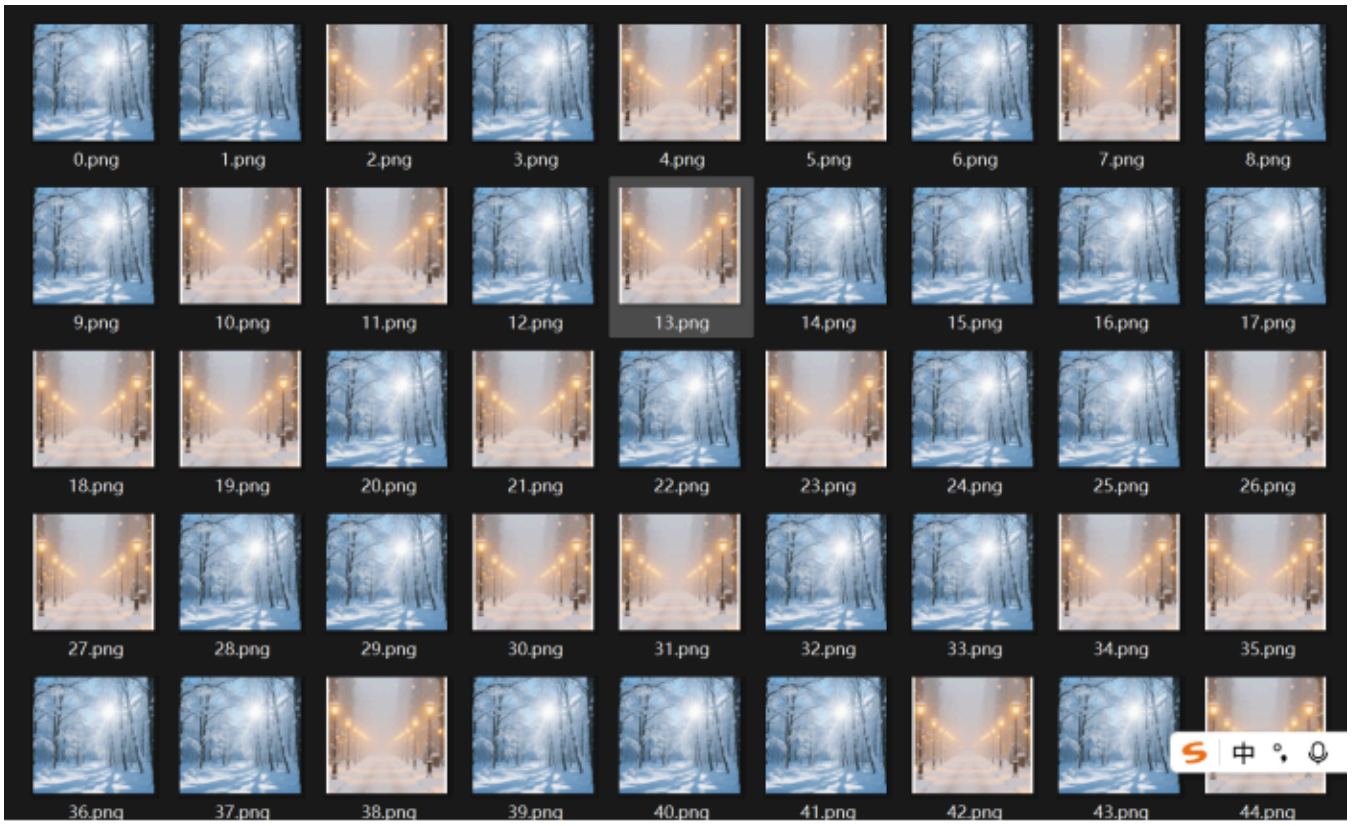
根据文件头判断文件为zip文件，修改文件后缀为.zip解压。

1、解压后的文件夹里的document文件，对文件中内容进行零宽隐写，得到第一段flag

2、使用foremost分离word文档，得到png图片，使用zsteg，得到第二段flag

```
root@kali: /home/kali/桌面
文件 动作 编辑 查看 帮助
└─# zsteg '/home/kali/桌面/00043963.png'
b1,g,lsb,xy           .. file: OpenPGP Public Key
b1,b,lsb,xy           .. file: OpenPGP Secret Key
b1,rgb,lsb,xy         .. text: "flag2:b-80de-035a"
b2,rgb,msb,xy         .. text: ",\r};=O]'2:"
b2,bgr,msb,xy         .. text: "C1E\t{Kz\t"
b2,rgba,lsb,xy        .. text: "'{{{{{ss//"
b2,abgr,msb,xy        .. text: "GGGOOOOOO"
b4,r,lsb,xy           .. text: "xfvdVfvwTEGfwDhj"
b4,r,msb,xy           .. text: "fn&\"\"*\"*\"\""
b4,g,lsb,xy           .. text: "EfeUS4EDC0"
b4,b,msb,xy           .. file: OpenPGP Public Key
b4,rgb,lsb,xy         .. text: "\"S6DwGtwGw"
b4,rgb,msb,xy         .. text: "Xi;I[\n[t"
b4,bgr,lsb,xy         .. text: "RF7twGtwD"
b4,bgr,msb,xy         .. file: OpenPGP Public Key
b4,rgba,lsb,xy        .. text: "O~/_?NON_\\OLO"

┌──(root㉿kali)-[/home/kali/桌面]
└─#
```

3、使用puzzlesolve对分离出的gif进行分帧，白色图片为1，黄色图片为0，根据图片获得二进制：00101101 00110100 00110101 00110011 00110010 00101101 01100001 00110110 00110101 00110111 01100110 00110110，获得第三段flag：-4532-a657f6



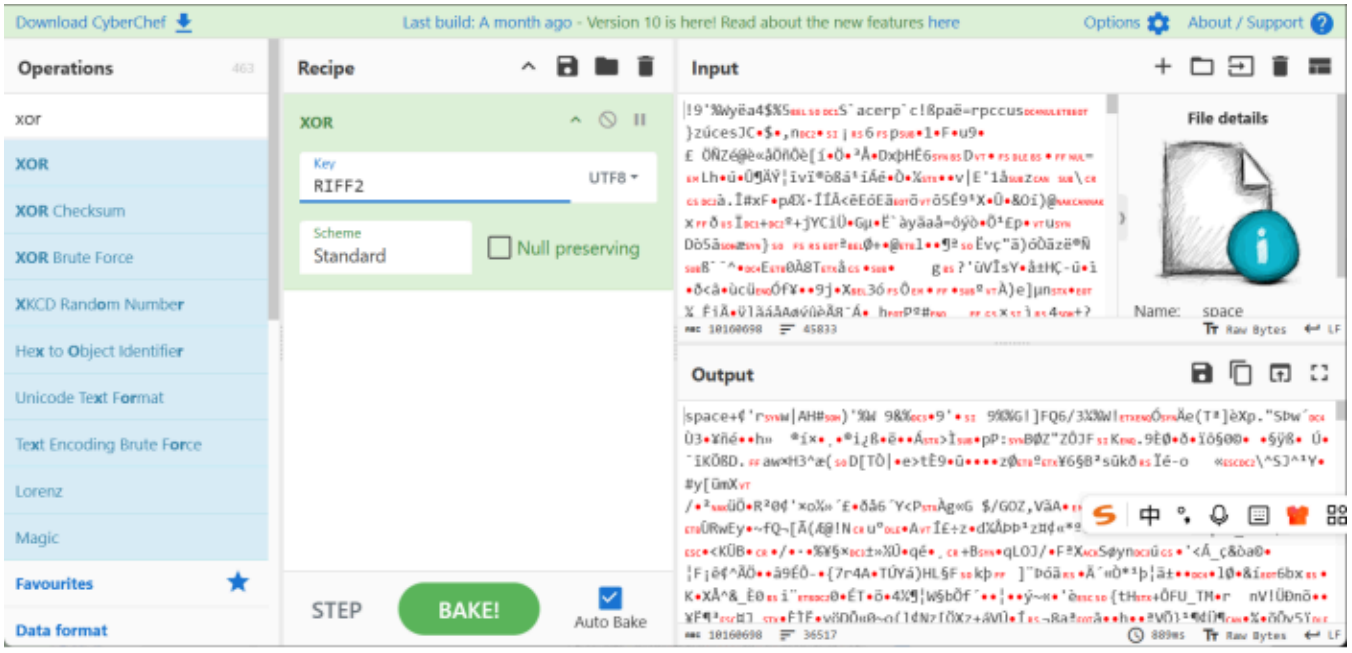
4、对文件中encl.html 及密码0602使用snow隐写工具，获得第四段flag：

```
Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----          2025/6/2     18:35           1972 encl.html
-a----        1998/11/22     15:56           4810 SNOW.DOC
-a----        1998/11/16     15:05          62464 SNOW.EXE


PS D:\CTF\SNOW> ./SNOW.EXE -C -p 0602 encl.html
5320ab}
```

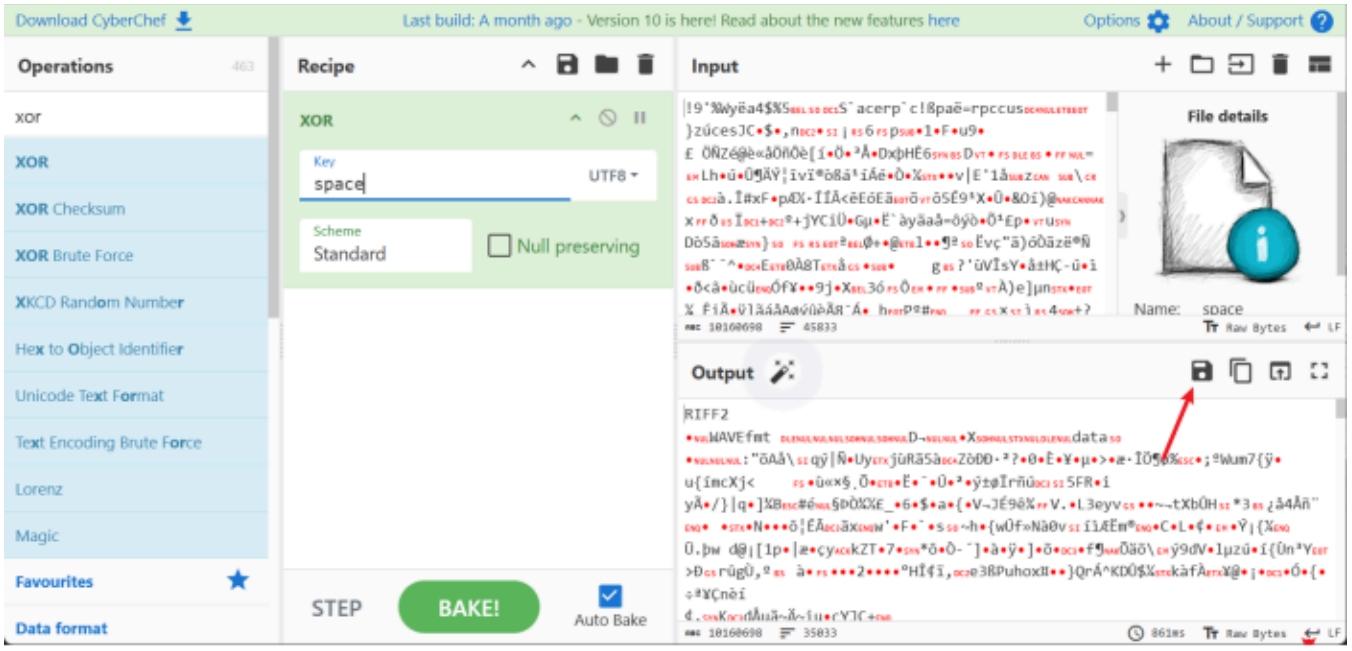
CRYPTO

回到原点

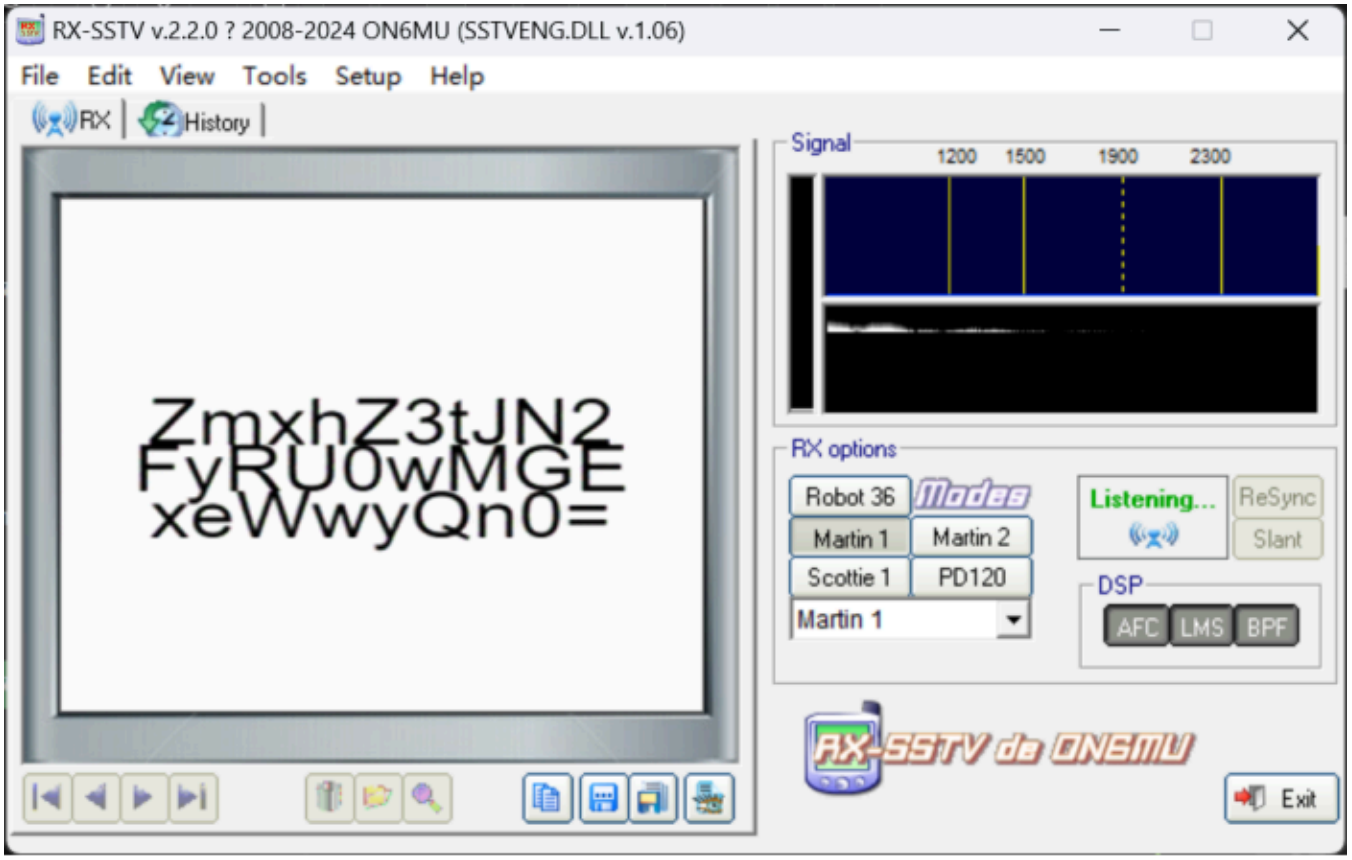
1、根据提示，space猜测是和太空，无线电相关，经过尝试去做xor RIFF2



2、再次尝试xor space 得到音频文件



3、保存以后设置虚拟声卡，得到图像，解码得到flag：flag{I7arEM00a1yl2B}



数据安全

你看看你的Windows7后面呢

参考以下，将文件重命名后即可使用帖子内原命令

https://blog.csdn.net/zong02023/article/details/143834432

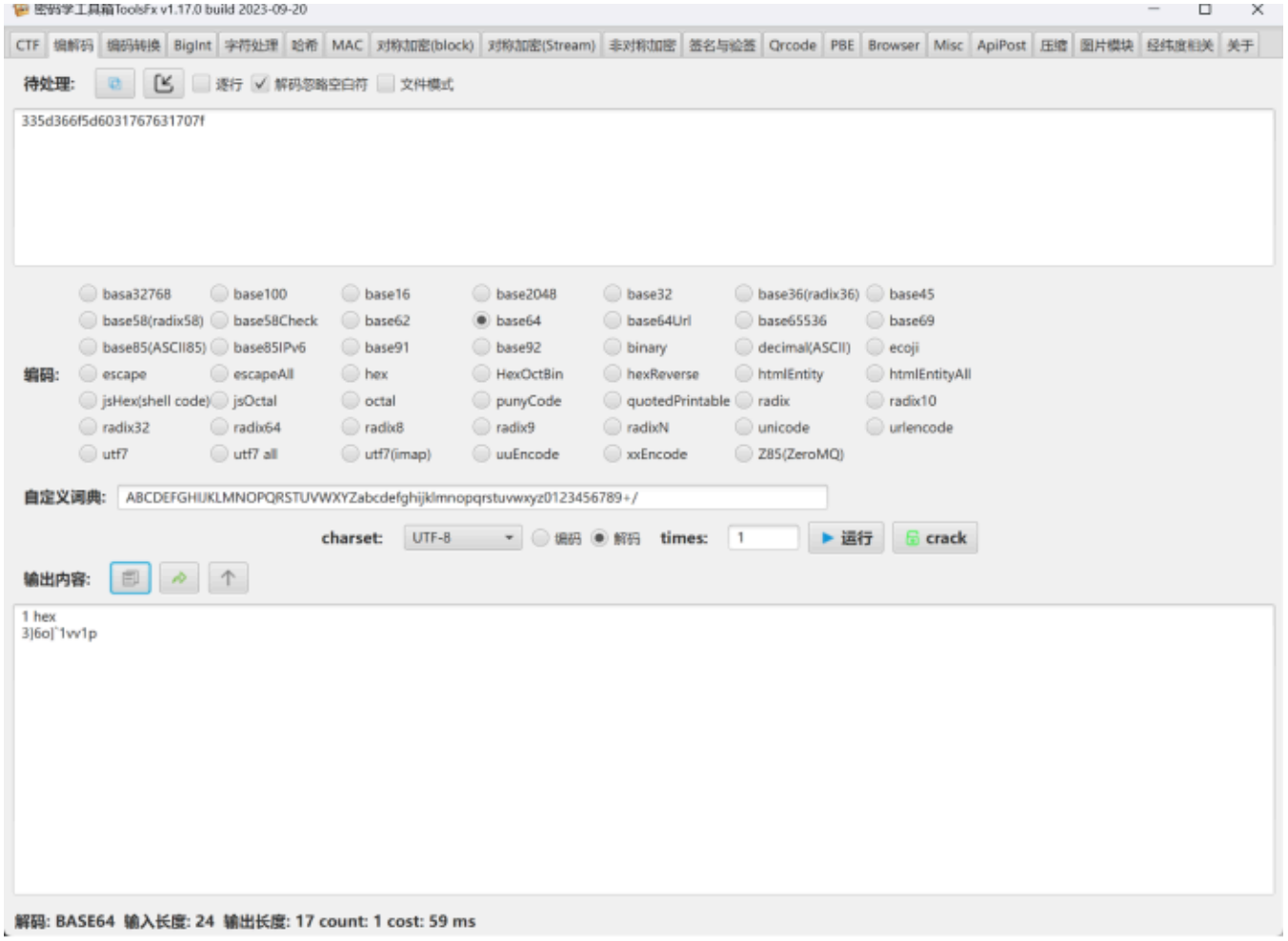
```
┌──(kali㉿kali)-[~/桌面/volatility-master]
└─$ python2 vol.py -f Challenge.raw --profile=Win7SP1x86_23418 pslist

Volatility Foundation Volatility Framework 2.6.1
Offset(V)  Name                    PID   PPID   Thds     Hnds   Sess  Wow64 Start
   Exit
---------- -------------------- ------ ------ ------ -------- ------ ------ ------------------------
-- ------------------------
0x83d09c58 System                    4      0     85      483 ------      0 2018-10-23 08:29:16 UTC+0000

0x8437db18 smss.exe                260      4      2       29 ------      0 2018-10-23 08:29:16 UTC+0000

0x84d69030 csrss.exe               340    332      8      347      0      0 2018-10-23 08:29:21 UTC+0000

0x84d8d030 csrss.exe               380    372      9      188      1      0 2018-10-23 08:29:23 UTC+0000

0x84d93c68 wininit.exe             388    332      3       79      0      0 2018-10-23 08:29:23 UTC+0000

0x84dcbd20 winlogon.exe            424    372      6      117      1      0 2018-10-23 08:29:23 UTC+0000

0x84debd20 services.exe            484    388     10      191      0      0 2018-10-23 08:29:25 UTC+0000

0x84def3d8 lsass.exe               492    388      7      480      0      0 2018-10-23 08:29:25 UTC+0000

0x84df2378 lsm.exe                 500    388     10      146      0      0 2018-10-23 08:29:25 UTC+0000
```

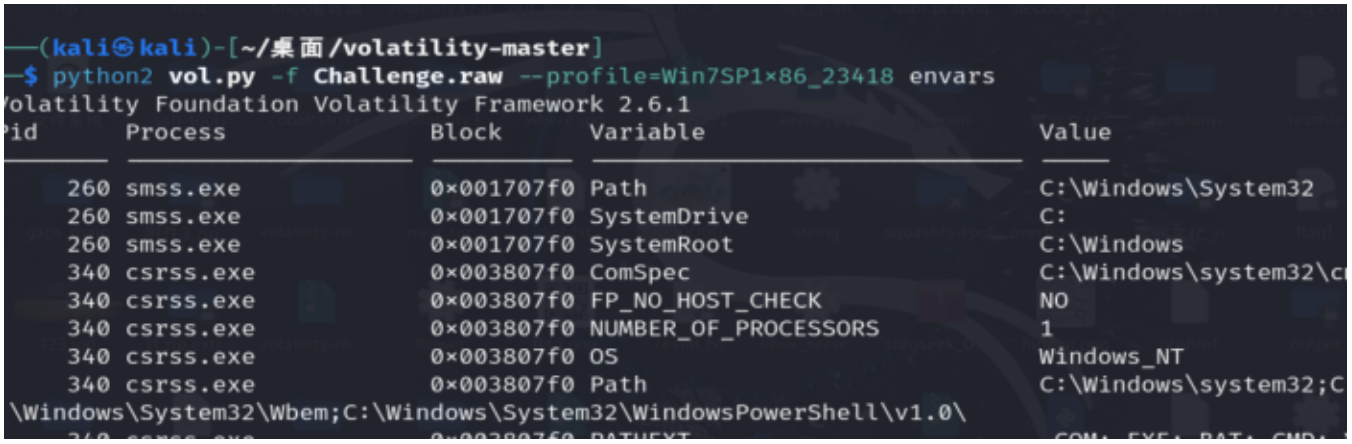
```
**************************************************
CommandProcess: conhost.exe Pid: 2104
CommandHistory: 0x300498 Application: cmd.exe Flags: Allocated, Reset
CommandCount: 1 LastAdded: 0 LastDisplayed: 0
FirstCommand: 0 CommandCountMax: 50
ProcessHandle: 0x5c
Cmd #0 @ 0x2f43c0: C:\Python27\python.exe C:\Users\hello\Desktop\demon.py.txt
Cmd #12 @ 0x2d0039: ???
Cmd #19 @ 0x300030: ???
Cmd #22 @ 0xff818488: ?
Cmd #25 @ 0xff818488: ?
Cmd #36 @ 0x2d00c4: /?0?-???-
Cmd #37 @ 0x2fd058: 0?-????
**************************************************
CommandProcess: conhost.exe Pid: 2424
CommandHistory: 0x2b04c8 Application: DumpIt.exe Flags: Allocated
CommandCount: 0 LastAdded: -1 LastDisplayed: -1
FirstCommand: 0 CommandCountMax: 50
ProcessHandle: 0x5c
Cmd #22 @ 0xff818488: ?
Cmd #25 @ 0xff818488: ?
Cmd #36 @ 0x2800c4: *?+?(???(
Cmd #37 @ 0x2ad070: +?(????

┌──(kali㉿kali)-[~/桌面/volatility-master]
└─$
```

```
┌──(kali㉿kali)-[~/桌面/volatility-master]
└─$ python2 vol.py -f Challenge.raw --profile=Win7SP1x86_23418 consoles

Volatility Foundation Volatility Framework 2.6.1
**************************************************
ConsoleProcess: conhost.exe Pid: 2104
Console: 0xe981c0 CommandHistorySize: 50
HistoryBufferCount: 2 HistoryBufferMax: 4
OriginalTitle: %SystemRoot%\system32\cmd.exe
Title: C:\Windows\system32\cmd.exe
AttachedProcess: cmd.exe Pid: 2096 Handle: 0x5c
----
CommandHistory: 0x300690 Application: python.exe Flags:
CommandCount: 0 LastAdded: -1 LastDisplayed: -1
FirstCommand: 0 CommandCountMax: 50
ProcessHandle: 0x0
----
CommandHistory: 0x300498 Application: cmd.exe Flags: Allocated, Reset
CommandCount: 1 LastAdded: 0 LastDisplayed: 0
FirstCommand: 0 CommandCountMax: 50
ProcessHandle: 0x5c
Cmd #0 at 0x2f43c0: C:\Python27\python.exe C:\Users\hello\Desktop\demon.py.txt
----
Screen 0x2e6368 X:80 Y:300
Dump:
```

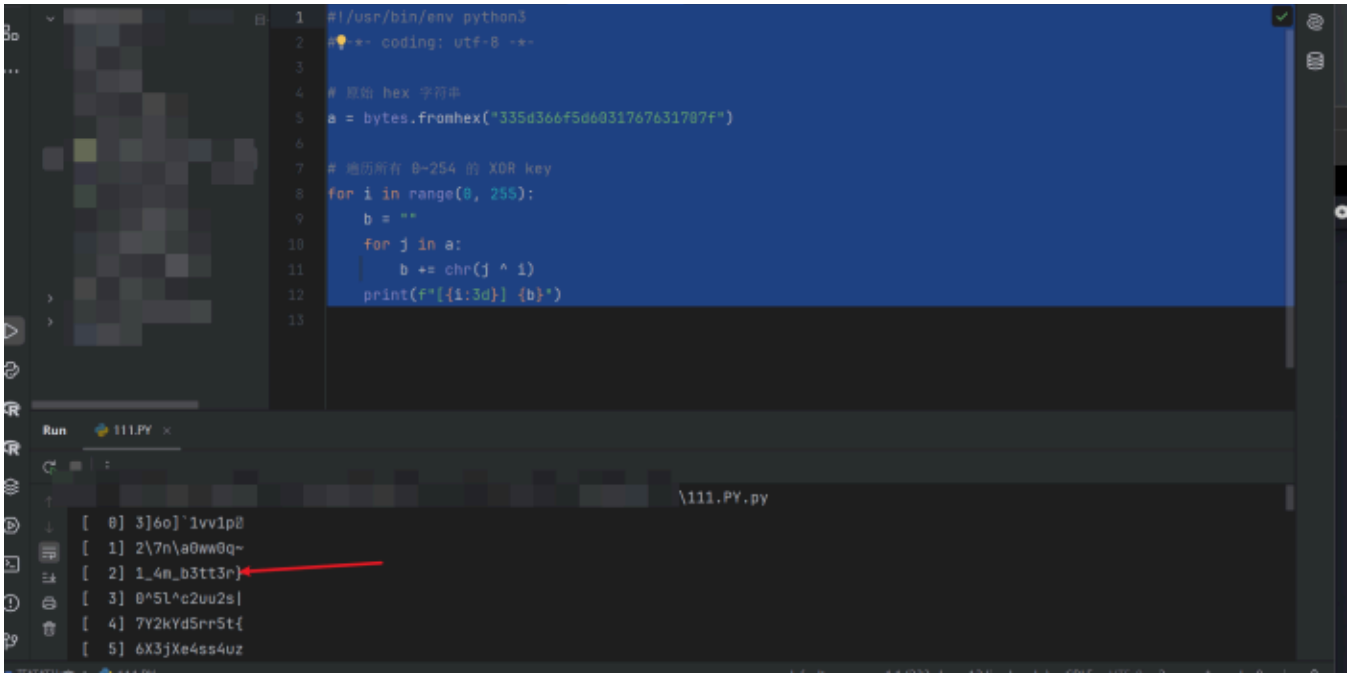
```
C:\Users\hello>C:\Python27\python.exe C:\Users\hello\Desktop\demon.py.txt
335d366f5d6031767631707f
```

解码得到，猜测是个秘钥 3]6o]`1vv1p



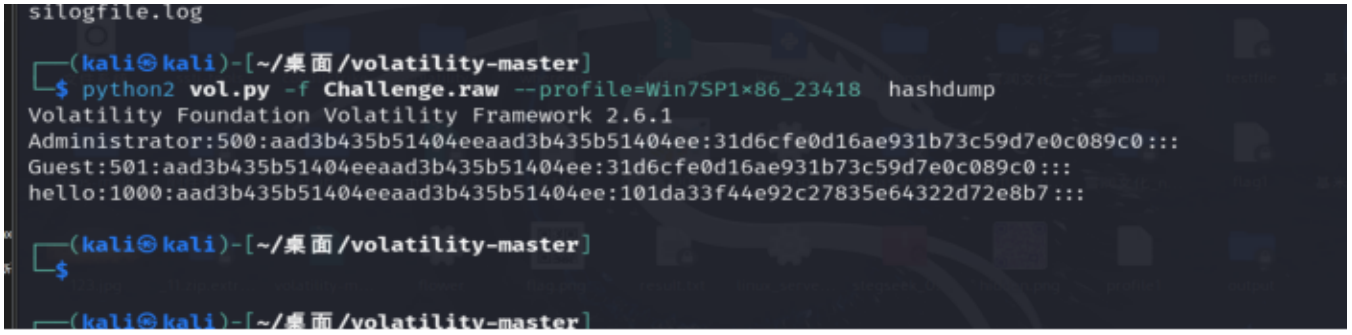



```
#!/usr/bin/env python3
# -- coding: utf-8 --

# 原始 hex 字符串
a = bytes.fromhex("335d366f5d6031767631707f")

# 遍历所有 0~254 的 XOR key
for i in range(0, 255):
  b = ""
  for j in a:
    b += chr(j ^ i)
  print(f"[{i:3d}] {b}")
#1_4m_b3tt3r}
```



、

前半段flag呢，查看hashdump，解密得到前半段flag



最后得到完整的flag

flag{you_are_good_but1_4m_b3tt3r}

WEB

运维系统

1. 根据附件提示的过滤情况和执行输出内容的命令，测试如下命令：
   127.0.0.1&pwd
   获得当前路径 /var/www/html。
2. 对function中命令进行调整如下：
   127.0.0.1&curl file:///var/www/html/key.ph{p} -o 3.txt
3. 直接访问 http://url/3.txt ，获得flag。

WEB

你知道我的密码吗

1. 根据附件提示的需构造反序列化，经过过滤后替换原来字段。
   查看正常反序列化字段，并考虑对age补充内容进行替换，内容如下：
   $age = ';i:1;s:6:"123456";i:2;s:3:"age';
2. 序列化内容中需替换部分如下：
   ";i:1;s:5:"abcbc";i:2;s:30:
3. 对username中增加xx字段数量，保证序列化并过滤之后，长度可以覆盖2中需要替换的内容，最终调整赋值结果如下：
   $username = "userxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx";
   $age = ';i:1;s:6:"123456";i:2;s:3:"age';
4. 拼接url后访问，得到flag。

WEB

一个简单的php反序列化

1. 根据页面内容提示的需通过魔法函数__toString()来调用Evil函数，即需对$c赋值类Lei2；
2. 新建类Lei1，对$a赋值为类Lei2；
3. 根据以上构造，并进行序列化;
4. 拼接url后访问，得到flag。

Misc

被篡改的PLC指令

1. 登录后，在tmp目录发现数据包；
2. wireshark访问数据包；
3. 根据命令码筛选;
4. 拼接data字段，得到flag。

数据安全

数据净化器

1. 查看py代码，发现上传csv文件；
2. 修改标题和内容，进行查看；
3. 构造系统命令执行os.systeme("ls")，得到正常返回0;
4. 构造命令得到flag。

数据库安全

Redis爱你呦

1. 通过Redis HLL 漏洞进行查询，发现漏洞CVE-2025-32023
2. 根据POC流程进行测试，得到服务端权限
3. 发现flag文件。

数据库安全

最近还好吗

1. ssh登录后发现flag文件，无权限
2. 搜索提权漏洞，发现sudo漏洞
3. 通过github的poc流程获得root权限，得到flag。